

The Ultimate Guide to Insider Threats

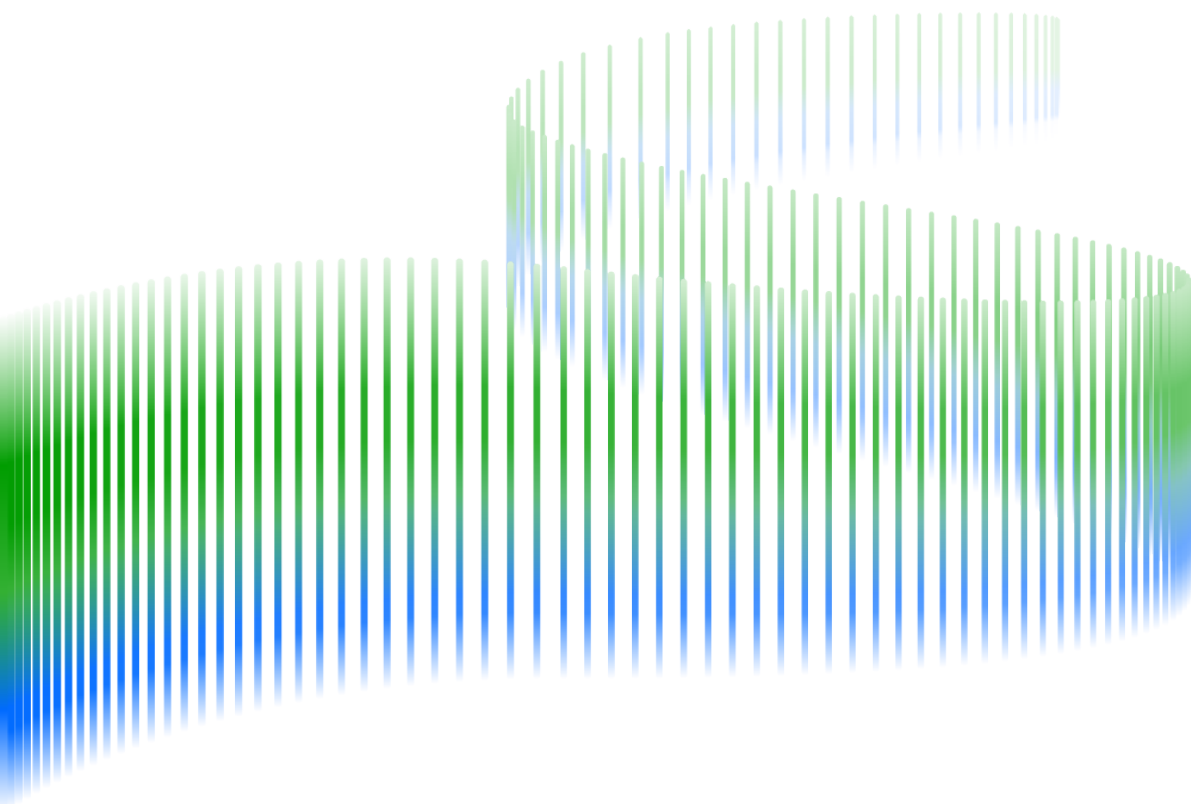


Table of Contents

3	Introduction
4	What Are Insider Threats?
6	Why Insider Threats Need Detection
7	A Modern Approach to Insider Threat Detection
8	Real-World Examples of Insider-Based Attacks
9	Insider Threat Activities and Data Feed Detection Points
11	Applying Data Science to Insider Threat Evaluation
12	Insider Threat Use Cases
20	What To Consider When Defending Against Insider Threats
22	Advanced Best Practices for Insider Threat Programs
23	Flexible Deployment Options for Comprehensive TDIR

Introduction

Insider threats remain one of the most persistent and costly challenges in cybersecurity—and they're only getting more complex. Unlike external attacks, insider threats often involve users with legitimate credentials and authorized access, making them significantly harder to detect with traditional security tools. According to the [2025 Ponemon Cost of Insider Risks Global Report](#):

- The average annual cost of insider threats has climbed to \$17.4 million, up from \$16.2 million in 2023.
- Employee negligence remains the most common cause, accounting for the majority of incidents.
- The average time to contain an insider incident has decreased slightly to 81 days, yet prolonged investigations still drive up total costs.
- Insider-driven data loss most often occurs through cloud and IoT channels, where visibility gaps persist.
- Organizations that deployed privileged access management (PAM) and security awareness training reported multimillion-dollar cost reductions.
- The average budget allocation for insider threat management has doubled, jumping from 8.2% to 16.5% of the total cybersecurity budget.

Organizations are recognizing that insider threats aren't just about malicious intent. Most are caused by negligence, human error, or external compromise—and nearly all involve someone trusted with access to critical systems. These insiders may be full-time employees, contractors, vendors, or third parties, working on site or remotely.

What makes insider threats so difficult to manage is that these users don't raise traditional red flags. Their activity looks legitimate—until it isn't. Without behavioral analytics or context-aware detection, security teams often miss the early signs of an incident.

That's why insider threat defense must go beyond rules and signatures. It requires a modern, use-case-driven strategy rooted in behavioral context, automation, and adaptable threat response.

This guide will help you:

- Define the different types of insider threats.
- Understand why insider threats often go undetected.
- Learn how simulation and training can strengthen defenses.
- Explore a modern detection strategy that uses AI and analytics.
- Examine applied case studies of insider attacks.
- Identify detection points and relevant data sources.
- Apply data science to insider risk detection.
- Map insider threat use cases to security operations.
- Implement best practices to improve insider threat programs.

We created this guide to help you take action, equipping your team with the knowledge and tools to detect, investigate, and respond to insider threats faster and more effectively.

What are Insider Threats?

Insider threats involve harmful actions carried out by users with legitimate access to an organization's network, systems, or data. While the term often refers to intentional misconduct, insider threats also include accidental or negligent behaviors that result in security incidents.

Anyone with access to your physical or digital environment can pose an insider threat, including:

- Current employees
- Former employees
- Contractors
- Business partners
- Researchers
- Outsourcers
- Suppliers
- Service providers
- Interns
- Students
- AI agents

In many organizations, these users may have access rights that are inappropriate, outdated, or excessive. It's common for system

permissions to be granted but rarely revoked. For example:

- Long-tenured employees may accumulate access to systems beyond the scope of their current role.
- A terminated employee's account may remain active due to an incomplete offboarding process.
- A contractor may be granted temporary access to specific data, but that access is never removed.

Compounding the challenge is the growing reliance on multiple cloud providers and SaaS applications. Tracking and managing access across these systems is complex and missteps are common.

These oversights create countless opportunities for insider threats, and they're often harder to spot than most security teams realize.

The amount of sensitive data exposed to insider risk is substantial. Common targets include:

- **Financial data** such as pre-earnings reports that could enable insider trading
- **Customer information**, including records that may be valuable to competitors
- **Product or technical documentation**—intellectual property (IP) that may be copied or exfiltrated
- **Employee data**, including HR, health, or compensation information

These assets don't live in just one place. They're routinely copied or moved for backups, compliance, development, testing, analytics, and reporting, expanding the potential attack surface.

Effective insider threat management starts with understanding who has access, what they're doing with it, and whether that behavior is expected.

Categories of Insider Threats

Insider threats typically fall into three categories, each with distinct motivations and risks.

Malicious Insider

A malicious insider is someone who intentionally seeks to harm the organization. This could be a current or former employee, contractor, or third party who abuses their access for personal gain or revenge. Motivations may include:

- Selling sensitive information for profit
- Sabotaging systems or data
- Exfiltrating IP before leaving for a competitor
- Responding to layoffs, demotions, or perceived mistreatment
- Being bribed or coerced into credential theft or data leakage

Malicious insiders often understand how to bypass internal controls and cover their tracks, making them especially dangerous.

Negligent Insider

Negligent insiders are well-meaning users who inadvertently put the organization at risk by ignoring or mishandling security policies. Examples include:

- Leaving a device unattended and unlocked
- Failing to update passwords or using weak credentials
- Sharing sensitive information via unsecured channels
- Ignoring software update prompts
- Skipping security awareness training
- Improperly offboarding from a role or internship
- While not malicious, these actions create exploitable gaps that can lead to serious incidents, especially when attackers are actively seeking ways to compromise accounts.

Compromised Insider

Compromised insiders are legitimate users whose credentials, devices, or accounts have been hijacked by external attackers. This often happens through:

- Phishing emails
- Social engineering
- Credential stuffing or brute-force attacks
- Malware infections
- Unauthorized use of third-party apps or shadow IT

Because these users appear to be operating normally, compromised insiders are particularly difficult to detect using static rules or traditional monitoring tools.

Each category poses unique challenges, and effective insider threat detection must account for all three. Behavioral analytics, automation, and context-aware investigation are critical to detecting early warning signs and reducing response times.

AI Agents: The Emerging Insider Threat

AI agents are quickly becoming part of day-to-day business operations. They can interact with enterprise systems, access sensitive data, and even take autonomous actions on behalf of your workforce. But this new efficiency introduces a new category of insider threat. Unlike external attackers, AI agents already operate with valid credentials and access rights. A misaligned, malfunctioning, hijacked, or jailbroken agent can create the same risks as a malicious insider, including data leakage, privilege misuse, inappropriate information disclosure, or unauthorized system changes, while often going unnoticed by traditional security tools.

How Exabeam Helps Secure AI Agents

Exabeam addresses this challenge by extending behavioral analytics and risk-based detection. By ingesting data from platforms like Google Cloud Agentspace, Google Cloud Model Armor, and custom agents built with Vertex AI or Agent Builder, Exabeam baselines both human and AI activity. Our Exabeam Nova AI agents score, explain, and prioritize anomalies so security teams can see when an AI agent deviates from its expected behavior and respond quickly. This approach closes a critical visibility gap, helping you secure your digital workforce.

Why Insider Threats Need Detection

Security policies, access controls, and preventative tools are essential, but they don't detect insider threats. Most traditional security technologies were built to protect the perimeter, operating under an outdated "inside versus outside" model. As a result, they're designed to catch incoming attacks, not suspicious behavior from users with valid credentials.

Even modern endpoint tools and network firewalls are limited when it comes to insider risk. They often miss the early signs of compromise or abuse because they rely on predefined signatures, and insider threats don't follow predictable patterns.

Security information and event management (SIEM) systems that depend on correlation rules face serious limitations when detecting insider threats:

- **Rules are static.** They follow rigid logic (for example, if condition A is met or threshold B is crossed), which don't account for the fluid nature of human behavior.
- **Context is missing.** Rules are broadly applied without consideration of entity-specific baselines, often triggering excessive false positives.
- **Historical trends are ignored.** Rules typically evaluate a short window of time and cannot incorporate long-term behavioral patterns or deviations.

These gaps make it difficult for security teams to detect the subtle indicators of misuse, negligence, or account compromise. User activity is dynamic. Roles change. Access patterns shift. Static tools don't adapt to these changes.

That's why insider threat detection requires behavior-based analysis—tools that learn what normal looks like for each user and can spot deviations in real time. Without this, many insider threats go undetected until after the damage has been done.

A Modern Approach to Insider Threat Detection

Traditional SIEMs were not built to catch insider threats. Static rules and signature-based detection often miss subtle behavioral changes, especially when the activity originates from valid credentials and authorized users.

Modern insider threat detection requires a fundamentally different approach—one that combines user and entity behavior analytics (UEBA), machine learning, and data science to understand context, adapt over time, and reduce noise.

UEBA works by collecting and enriching data from a broad range of sources, including:

- Identity providers (for example, Active Directory (AD) and Okta)
- Data loss prevention (DLP) tools
- Physical access systems
- Cloud infrastructure and SaaS applications
- Threat intelligence feeds
- Authentication and authorization logs
- Network traffic and DNS activity

With this data, UEBA builds behavioral baselines for every user and device, learning what's typical in terms of access patterns, login times, data usage, and privilege levels. Over time, the system can detect deviations from these baselines, even if the behavior wouldn't trigger traditional alerts.

This type of behavior-based analysis can surface insider threats without relying on predefined signatures or static thresholds. It identifies risky activity in real time and over extended periods, accounting for long-term trends and entity-specific context.

Increasingly, agentic AI is being used to strengthen these detection capabilities. Unlike basic automation or chat-based tools, agentic AI can act independently on behalf of analysts, connecting data points, highlighting likely risks, and guiding investigative next steps. This helps reduce cognitive load and speeds up the identification of insider activity, especially in complex environments.

To be effective, a modern insider threat detection system must combine:

- **High-scale data processing** for ingesting diverse logs and telemetry
- **Adaptive ML models** that account for evolving behavior
- **Contextual awareness** that factors in user roles, peer groups, and historical trends

These capabilities shift the focus from reactive to proactive, allowing teams to identify, investigate, and mitigate insider threats before they escalate.

Real-World Examples of Insider-Based Attacks

Insider threats don't always start with malicious intent. But over time, through negligence, opportunity, or deliberate action, insiders can cause serious damage. Here are examples across a spectrum of severity:

- A sales manager copied customer and pipeline forecasts before leaving to join a competitor.
- An engineer preparing to launch a startup downloaded proprietary product plans and technical documentation.
- An IT manager accessed quarterly earnings reports ahead of their release, intending to profit through insider trading.
- A scientist at Dow Chemical copied thousands of confidential R&D files and attempted to sell them to a foreign government. He was sentenced to five years in prison in 2012.
- A government contractor downloaded large volumes of classified data and leaked it to the press, exposing national security programs.
- A data analyst took home a hard drive containing personally identifiable information (PII), which was later stolen in a home burglary.
- An employee fell for a phone-based phishing (vishing) attack, handing over credentials that enabled external attackers to access the internal network.
- A customer support staffer sold their credentials to the Lapsus\$ hacking group for \$10,000–\$20,000, providing a backdoor into sensitive systems.
- An engineering intern failed to change a default password, leaving a development environment exposed, ultimately contributing to a software supply chain breach.

In each case, the insider used or accessed systems in ways that were abnormal or unauthorized. Some actions were malicious. Others were negligent. Some were the result of compromise.

In hindsight, the signs seem obvious. For example, in the Dow Chemical case, the employee accessed secure servers 10 times more frequently than peers in the same role.

The problem? Those indicators are rarely centralized. They're scattered across logs, systems, and tools, making them hard to detect, correlate, and investigate in time to prevent damage.

Insider Threat Activities and Data Feed Detection Points

Understanding where and how insider threats occur is key to identifying them early. The following examples outline common insider threat activities and their associated detection points across your environment.

Insider Threat Activities

Endpoints

- Is the user copying files to a USB device?
- Are these files different from their usual activity—confidential or unusually large in volume?
- Are they sending data to a personal email or file-sharing account?

File servers

- Is a contractor accessing sensitive directories they don't normally use?
- How many files are they reading or copying?
- Is this behavior consistent with others in similar roles?

Identity management systems

- Is a service account behaving like a user account?
- Has the user's access changed recently—new roles, groups, or elevated privileges?
- Are reconnaissance tools like BloodHound active in the environment?

Database servers

- Does the user typically access this database or table?
- Are they querying large volumes or sensitive tables not tied to their role?

Badge readers

- Are badge-ins or badge-outs occurring at odd hours or unusual locations?
- Is the person entering a building or server room for the first time?

Printers

- Are files being printed after hours or in high volume?
- Is someone printing unnamed documents—a common method of covert data exfiltration?

Development systems

- Are code review protocols being bypassed?
- Are best practices for certificate and credential management being followed?

Cloud Applications

- Is a contractor uploading files to Box, OneDrive, or another unsanctioned cloud app?
- Are those files tagged as sensitive by your DLP tools?

Data Feeds for Insider Threat Evaluation

Monitoring individual sources can raise red flags. But connecting the dots across these feeds is what turns signals into insights:

- **Access logs:** VPN, Wi-Fi, and domain controller logs track where and how users connect.
- **Identity services:** Systems like AD, Okta, and Ping Identity provide role, peer, and location context.
- **DLP scans:** Tools like Broadcom/Symantec and Netskope help classify and monitor sensitive data movement.
- **Endpoint telemetry:** Endpoint detection and response (EDR) solutions like SentinelOne, Carbon Black, and CrowdStrike offer detail on file access, transfers, and configuration changes.
- **Network flow data:** NetFlow and packet analysis can help contextualize traffic volumes and destinations.
- **Database logs:** Native logs or tools like Imperva database firewalls track access to sensitive data tables.
- **Application activity:** Includes both access control and in-app user activity logs
- **Cloud logs:** Most IaaS and PaaS platforms offer logs that indicate file uploads, downloads, sharing, and permission changes.
- **USB device access:** File transfers to removable media are critical indicators when correlated with DLP results.
- **Print server logs:** Printing out sensitive data is a low-tech but common tactic.
- **Physical access controls:** Badge reader logs can correlate physical presence with digital activity.

Each of these signals matters. But reviewing them in isolation isn't enough. Making sense of them requires real-time correlation, baseline comparison, and behavioral analysis at a scale that exceeds human capacity.

This is where automation, UEBA, and AI come into play, identifying threats that would otherwise remain hidden in the noise.

Applying Data Science to Insider Threat Evaluation

The volume and complexity of data generated across systems—from identity platforms and cloud services to endpoints and physical security—is beyond what human analysts can manage alone. To evaluate insider threats accurately and at scale, ML and data science techniques are essential.

A modern SIEM equipped with behavioral analytics and automation should provide the following capabilities:

Behavioral Baseline

Establish a unique behavioral baseline for each user and device. By monitoring historical activity, the system can determine what's typical and assign risk scores to deviations that signal potentially suspicious behavior.

Peer Group Analysis

Compare individual user behavior against a dynamic peer group of users with similar roles or access levels. A new action may be unusual for the user but common for the group—an important distinction that reduces false positives and improves investigation accuracy.

Privileged Account Monitoring

Privileged users often have broad access to sensitive data. A modern system must factor this into risk scoring, closely monitor privilege escalation events, and highlight unusual or unauthorized use of administrative credentials.

Shared Account Analysis

Shared accounts present visibility and accountability challenges. Advanced analytics can detect patterns that indicate account sharing, attribute sessions to likely users based on behavior, and flag high-risk activity tied to shared credentials.

Locked Account Correlation

Account lockouts can be benign or a signal of attempted misuse. Analytics should flag lockouts associated with dormant accounts, users switching toles, or privilege changes. Investigating activity before and after a lockout helps expose risky insider behavior or credential misuse.

Once the system identifies abnormal behavior or risk signals, it can initiate a range of responses:

- **Notify an analyst** for manual review.
- **Send a reminder** to the user about policies or confidentiality agreements.
- **Trigger automated containment actions** such as access restrictions, workflow escalation, or incident response playbooks.

By combining advanced analytics with automation, modern SIEM platforms reduce dwell time, accelerate investigations, and limit the damage insider threats can cause—before the organization even realizes there's an issue.

Insider Threat Use Cases

Detecting, investigating, and responding to insider threats—whether malicious, compromised, or negligent—requires more than static rules and manual log review. Legacy SIEMs force analysts to stitch together sessions from fragmented logs, often missing key relationships across users, entities, and behaviors.

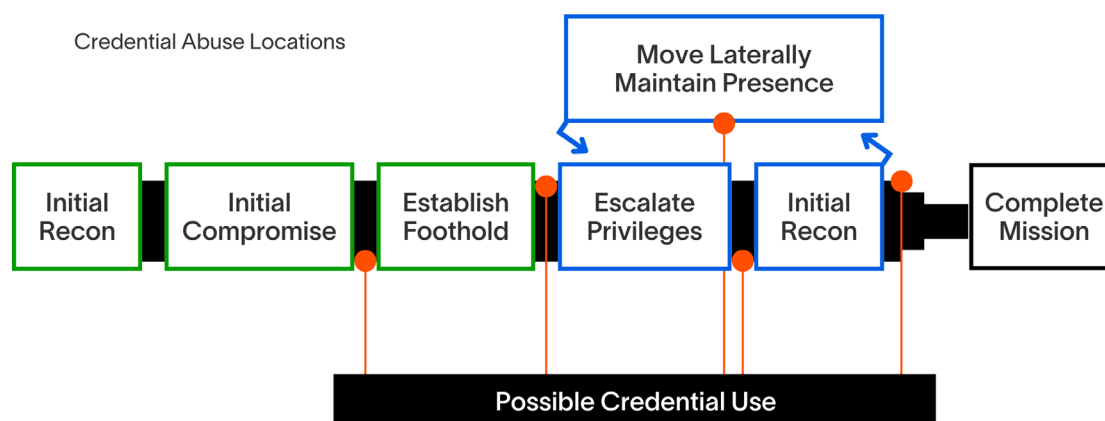
Modern insider threat detection depends on UEBA, automation, and prebuilt use case content designed to spotlight early indicators of compromise. These capabilities enable faster investigations, reduce alert fatigue, and improve security operations center (SOC) productivity.

The following seven use cases represent high-risk behaviors commonly associated with insider threats and how modern analytics can detect them.

1. Compromised Credentials

Definition

Compromised credentials occur when legitimate usernames and passwords are stolen or misused by attackers to access internal systems. The compromise may be unintentional (for example, phishing) or deliberate (for example, sold for profit, as seen in the Lapsus\$ attacks).



Problem

Attackers use various techniques to obtain valid credentials:

- **Phishing/spear-phishing:** Deceiving users into entering credentials on malicious sites
- **Password spraying:** Testing common passwords across known usernames
- **Credential stuffing:** Reusing stolen credential pairs from breaches
- **Keylogging:** Capturing keystrokes through malware or Bluetooth injection
- **Brute force:** Attempting large volumes of password combinations
- **Social engineering:** Manipulating users into disclosing access details
- **AD Reconnaissance:** Mapping directory structure using tools like BloodHound to identify high-value accounts and relationships

Solution

Modern SIEMs use UEBA to establish behavioral baselines for every user and asset. Anomalous login times, device usage, or geolocation inconsistencies trigger risk scoring models.

When credential misuse occurs, the system aggregates these anomalies with fact-based rules and correlation logic, assembling a unified timeline of suspicious activity. This reduces noise while providing context for analysts to triage threats efficiently.

The result: higher-fidelity detections with fewer false positives and a faster path to containment.

2. Lateral Movement

Definition

Lateral movement refers to an attacker's progression from one compromised system to others within the internal network. After gaining access through compromised credentials, the attacker explores the environment to find high-value assets or escalate privileges.

Problem

Common techniques used to move laterally include:

- **Port scanning:** Using tools like Nmap to discover vulnerable systems and expand access
- **Remote desktop access:** Leveraging RDP sessions when a legitimate user is inactive
- **SMB exploitation:** Abusing Windows Server Message Block (SMB) for credential pass-through using PsExec or scheduled tasks
- **Pass-the-hash:** Reusing stolen NTLM password hashes to authenticate across systems
- **Golden and silver tickets:** Exploiting Kerberos to forge ticket-granting tickets (TGTs) and gain domain access
- **Pass-the-ticket:** Stealing existing Kerberos tickets and reusing them to impersonate users on other devices

Solution

Advanced SIEMs detect lateral movement by correlating log events, authentication activity, and entity behavior. Prebuilt use case content, often mapped to frameworks like MITRE ATT&CK®, help flag indicators such as:

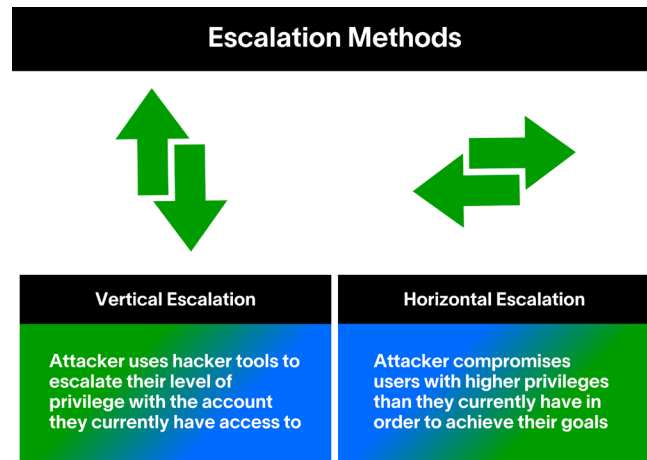
- Abnormal port scans
- Remote desktop session activity
- Unauthorized service creation or process execution
- Signs of Kerberos ticket manipulation

Behavioral models assign risk scores and prioritize users or asset exhibiting east-west movement patterns. Visual timelines, watchlists, and contextual alerts help analysts investigate lateral movement in minutes instead of hours, reducing dwell time and limiting impact.

3. Privilege Escalation

Definition

Privilege escalation is the process by which an attacker gains unauthorized access to elevated permissions. This allows them to move from a compromised user account to one with broader or administrative access—often a critical step in achieving control over sensitive systems and data.



Problem

Attackers use a variety of techniques to escalate privileges:

- **Horizontal escalation:** Leveraging compromised accounts to access other systems with similar privileges in search of escalation opportunities
 - **Vertical escalation:** Bypassing security controls to move from a low-privilege account to one with administrative rights
 - **Account discovery and switching:** Abnormal switching between accounts or services can indicate exploration or escalation attempts
 - **Credential dumping:** Extracting password hashes (for example, from the SAM database) to impersonate users or reuse credentials across systems
 - **Weak configurations:** Exploiting misconfigured permissions, Group Policy Objects (GPOs), or executable files to bypass controls
- These techniques often occur during the post-exploitation phase of an attack, when the adversary is already embedded in the environment.

Solution

Modern SIEMs detect privilege escalation by building behavioral baselines for each user and device. The system flags anomalies such as:

- Sudden changes in access behavior
- Use of new or unapproved accounts
- Unusual privilege elevation events
- Lateral access to sensitive assets from low-privilege users

Correlation rules and behavior models assign risk scores to privilege-related activity. Prebuilt use case content—mapped to frameworks like ATT&CK—highlights privilege escalation attempts and places them within a timeline for investigation.

By assembling related alerts into a unified view, analysts can quickly understand the scope of the threat and initiate a targeted response, reducing the window of opportunity for attackers to escalate further or exfiltrate data.

4.Privileged Activity

Definition

Privileged activity refers to actions performed by accounts or users with elevated access, such as administrators, service accounts, or root-level roles. These accounts have broad control over systems, sensitive data, and network infrastructure, making them high-value targets for attackers.

Problem

Privileged accounts introduce heightened risk for several reasons:

- **Privileged users:** Individuals such as system administrators or executives with access to sensitive information, systems, or privileged workflows
- **Service accounts:** Non-human accounts used by applications or scripts that often lack password rotation policies and are shared across environments
- **Privileged assets:** Systems hosting critical data, such as financial records, PII, or proprietary IP. These include servers, databases, and cloud infrastructure
- **Domain controllers:** Central to authentication and access management, but often difficult to monitor due to high event volume

Attackers who gain access to privileged accounts can bypass most security controls, disrupt operations, and exfiltrate sensitive data, often without immediate detection.

Solution

Modern SIEMs provide visibility into privileged accounts and help security teams define, monitor, and manage privileged activity. Capabilities should include:

- Behavioral baselining of privileged users and service accounts
- Real-time detection of abnormal access or command execution
- Contextual insights into asset sensitivity and role-based risk scoring
- Timeline views that assemble events tied to privilege misuse

By identifying privilege-related anomalies, such as an admin accessing unfamiliar assets, service account drift, or unscheduled policy changes, the system alerts analysts early. This allows teams to investigate and respond before attackers can escalate or expand access.

Context Tables

Context tables contain a grouped set of values that allow you to manage multiple entities with a single input

ex. The user_is_executive context table contains executives, starting with the CEO and two rungs down the organizational hierarchy ladder.

User and Asset Labels

Contain a set of accounts or assets that allow you to manage multiple entities with a single input

ex. Applying a label of "Admin" to all user accounts with administrative privileges is a good way to provide context to a user profile.

Monitored Entities

Correlation rules and anomalies can quickly identify insider threats, sort by risk and escalate them into cases

ex. Creating a correlation rule with an "Admin" user label where any risk higher than 50 will create a case

Evasion

Definition

Evasion refers to techniques attackers use to avoid detection after gaining access to a network. Once inside, adversaries often attempt to suppress logs, obfuscate their activity, and maintain persistence—sometimes for months—while progressing toward their objective.

Problem

Evasion techniques vary widely, but the goal is consistent: Avoid alerting defenders. Common methods include:

- **PowerShell misuse:** Launching or hiding processes using PowerShell to suppress or delete logs
- **Encoded commands:** Obfuscating scripts or commands using Base64 or hexadecimal encoding
- **Log tampering:** Disabling auditing, clearing logs, or deleting forensic artifacts to erase evidence
- **TOR and proxy use:** Obscuring source IP addresses and routing communications through anonymizing networks

- **Process injection and manipulation:** Unloading Sysmon, disabling Windows logging, or renaming malicious tasks to appear benign
- **Living-off-the-land tools (LOLBins):** Abusing trusted tools like WMI, PsExec, or task schedulers to blend into normal activity

Evasion complicates detection, inflates dwell time, and makes post-incident investigation far more difficult, increasing the risk of long-term compromise.

Solution

Modern SIEMs combine fact-based detection (known indicators of compromise (IoCs), suspicious commands, etc.) with behavior-based models to flag anomalies in user, device, and process activity. Key capabilities include:

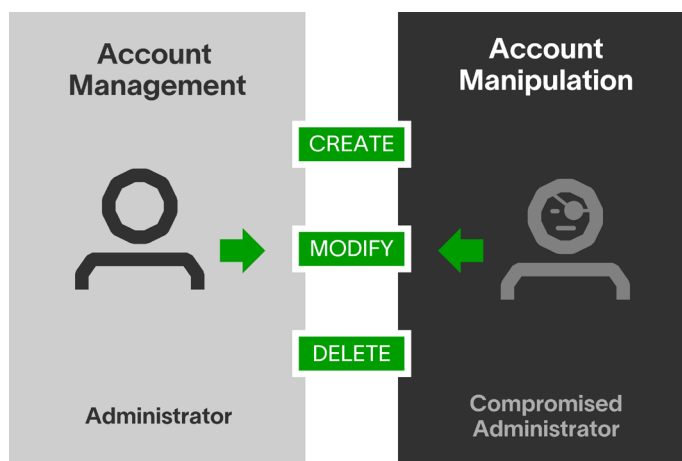
- Recognizing execution of known LOLBins and malware frameworks
- Detecting command-line arguments designed to bypass security controls
- Highlighting gaps in logging or audit trails
- Tracking long-term behavioral drift that suggests persistence or stealth techniques

Enrichment from threat intelligence, including TOR exit nodes, malicious DNS domains, and known C2 infrastructure, further strengthens detection. By surfacing subtle signals and correlating them across users and systems, a modern SIEM reduces attacker dwell time and gives analysts a clearer view of hidden threats.

Account Manipulation

Definition

Account manipulation involves an attacker modifying user or service accounts to gain access, escalate privileges, or maintain persistence within the environment. This includes changing roles, permissions, group memberships, or creating and deleting accounts to mask activity.



Problem

Account manipulation is often a follow-on action to credential compromise, privilege escalation, or lateral movement. Techniques include:

- **Directory service abuse:** Exploiting tools like AD to discover users, roles, and access rights, then modifying those rights to escalate privileges
- **Unauthorized account creation or deletion:** Creating new privileged accounts or deleting logs of previous ones to evade detection

- **Group membership changes:** Assigning excessive permissions to an existing user to access sensitive data or systems
- **Permission escalation through system vulnerabilities:** Modifying scheduled tasks, registry settings, or configuration files to elevate access rights

Attackers use these techniques to legitimize their presence and conduct operations under the guise of normal users, making detection more difficult without behavior-based insight.

Solution

Modern SIEMs detect account manipulation through:

- **Behavioral analytics:** Establishing a baseline for account management activities and surfacing deviations
- **Prebuilt use case content:** Detecting anomalies in account creation, deletion, group membership, and permission changes
- **Correlation of identity events:** Connecting the dots between account changes and other suspicious actions, such as privilege escalation or lateral movement
- **Entity risk scoring:** Assigning scores based on both historical behavior and the sensitivity of accounts being modified

The system should alert on abnormal directory service interactions and unexpected changes to system or user accounts—especially those associated with high-value assets or privileged roles. By identifying these manipulations early, security teams can prevent attackers from expanding control or covering their tracks.

Data Exfiltration

Definition

Data exfiltration is the unauthorized transfer of sensitive data out of an organization's network. Unlike denial-of-service or destruction-focused attacks, exfiltration is typically covert and methodical, often carried out by insiders or sophisticated adversaries with specific targets in mind.

Problem

Adversaries go to great lengths to avoid detection when stealing data. Common exfiltration techniques include:

- **Encoding and fragmentation:** Splitting data into small chunks and sending it through DNS requests or other low-profile channels
- **Tunneling:** Using SSH port forwarding, reverse shells, or web shells to transmit data undetected

- **Removable media:** Copying files to USB drives or external devices, especially outside business hours
- **Cloud sync abuse:** Uploading files to unauthorized cloud services like Box, Dropbox, or personal OneDrive accounts
- **Stealth transmission:** Using encrypted channels, obscure ports, or renamed file types to mask content

Legacy SIEMs often miss these behaviors, especially when data is exfiltrated in small volumes, through trusted channels, or by users with legitimate access

Solution

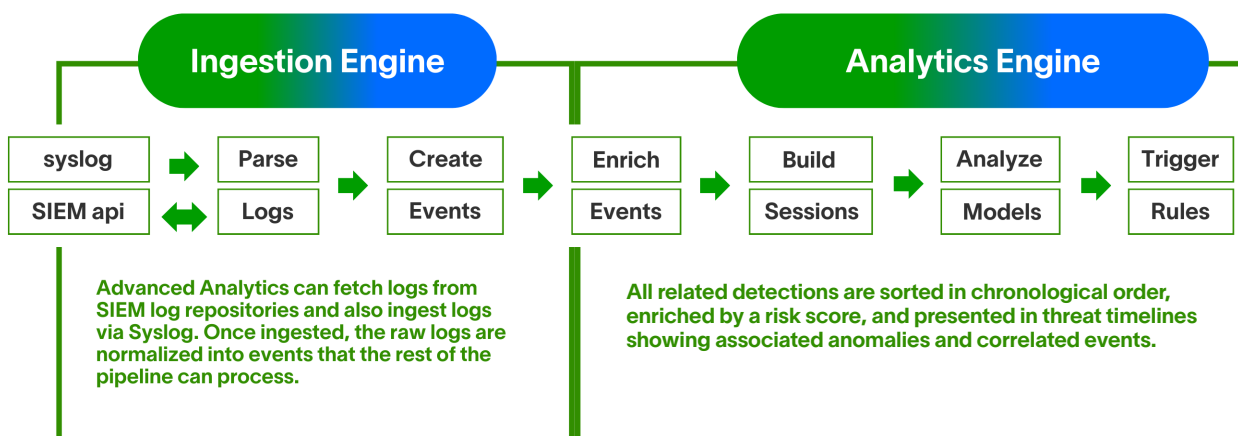
Modern SIEMs detect data exfiltration by combining behavioral analytics, known attack signatures, and enriched context. Key detection capabilities include:

- **UEBA-driven baselines:** Detecting anomalies in data transfer volume, destination, timing, and user behavior
- **Process monitoring:** Highlighting use of tools and utilities known for exfiltration, such as network sniffers or file compression utilities

- **Cloud and endpoint integration:** Surfacing unauthorized data uploads or removable media usage in conjunction with DLP verdicts
- **Risk scoring and correlation:** Elevating the visibility of users or systems that exhibit suspicious activity across multiple dimensions (for example, privilege changes, login anomalies, or transfer behavior)

By analyzing exfiltration attempts in the context of broader user behavior and system activity, modern platforms reduce false positives and give analysts actionable, high-confidence alerts.

Data Flow in Advanced Analytics



What To Consider When Defending Against Insider Threats

If your organization hasn't yet established an insider threat program, now is the time. The following recommendations can help you build a comprehensive, effective strategy that spans policy, process, and technology.

1. Form a Cross-Functional Planning Team

Start by assembling a team with broad organizational representation. Include stakeholders from security, IT, legal, HR, compliance, and executive leadership, particularly your Data Privacy Officer, if applicable. This team should define policies and procedures that reflect both business realities and legal obligations, covering everything from onboarding and job changes to terminations and incident response.

2. Identify and Prioritize Critical Assets

With the right people in place, inventory your most valuable assets—both digital and physical. These might include source code, product designs, customer lists, financial systems, SaaS environments, employee records, or facility access controls. Use your team's combined knowledge to assess business impact and create a watchlist of high-risk systems. This ensures your insider threat program focuses resources where they matter most.

3. Conduct a Threat Risk Assessment

Evaluate your current environment for exposure to insider threats. Assess gaps in your tools, processes, and configurations. This may include:

- Auditing system configurations against security benchmarks
- Verifying alignment with internal access policies
- Running penetration tests or red-blue team exercises
- Testing visibility into insider behaviors, such as large file transfers, access anomalies, or peer group deviations

The goal is to understand how effectively you can detect malicious or risky activity from trusted users.

4. Perform Employee Background Checks

While not foolproof, background checks can reveal risk factors like prior policy violations or financial distress. Use them as part of a holistic assessment but stay aware of potential inaccuracies or outdated information. Combine with clear internal policies on ethical conduct, acceptable use, and access controls.

5. Implement and Enforce Access Controls

Limit data access based on job function. Provide only the minimum privileges required to perform work. Where temporary access is needed, grant it with time-based controls. Use encryption and policy enforcement to minimize the damage from credential misuse—whether accidental or malicious.

6. Build Insider Threat Use Cases

Document common insider threat scenarios relevant to your organization, such as unapproved cloud uploads, unauthorized access requests, or risky behavior during employee offboarding. Include monitoring procedures for high-risk events like resignations or layoffs. These use cases help your SOC respond consistently and proactively, and often align with compliance requirements or industry best practices.

7. Evaluate Monitoring and Detection Tools

If current tools can't provide the visibility or context you need, evaluate solutions with built-in behavioral analytics, automated threat detection, and centralized investigation workflows. Prioritize platforms that provide:

- End-to-end visibility into user and entity activity
- Real-time alerting on behavioral anomalies
- Unified monitoring, logging, and response capabilities

These tools improve analyst efficiency and reduce mean time to detect.

8. Continuously Audit and Adapt Your Program

Threats evolve. Your program should, too. Conduct regular audits of access controls, tool effectiveness, and program maturity. Learn from every incident. Feed those insights back into your processes to prevent recurrence. Static programs create visibility gaps. Iterative programs create resilience.

And don't overlook the human element. Security awareness training—including phishing simulations, password hygiene, and acceptable use reminders—goes a long way in reinforcing a strong security culture.

And don't forget the importance of employee security education. Creating awareness of phishing, securing physical assets, and even discussions on “why never to use work credentials in non-work-related tools, sites, or apps” can make a difference.

Advanced Best Practices for Insider Threat Programs

As you refine your insider threat program, the following best practices can help ensure it's effective, scalable, and trusted without compromising productivity or team morale.

Use Language That Builds Trust

The words you choose shape how your program is perceived. Overly aggressive or punitive terminology can create an "us versus them" mindset, undermining engagement.

Consider naming your initiative something more neutral or supportive, like an "employee protection program" or "workforce security program." The goal is to frame the initiative as collaborative—focused on safeguarding people, assets, and operations—not as surveillance or punishment.

When employees feel like partners in security, they're more likely to follow best practices, report concerns, and help prevent incidents before they escalate.

Be Transparent About Intent

Transparency fosters trust. While you don't need to share every technical detail, clearly explain what the program monitors and why. Emphasize that the goal is to protect the organization—and its people—from unintended harm, not to scrutinize individuals.

Encourage everyone, including contractors and interns, to report suspicious behavior or unusual system activity. Make reporting accessible and clearly communicate how to do it. Employees are more likely to speak up if they understand the stakes and trust the process.

Prioritize Automation Over Manual Monitoring

Manual review of logs and access events is time consuming and error prone—and it doesn't scale. Insider threats often unfold slowly and blend in with normal behavior, making them difficult to catch without support from automation and analytics.

Automated monitoring helps security teams:

- Analyze behavior across users, assets, and applications
- Detect subtle deviations that signal risk
- Focus on response and remediation instead of log triage

Insider threat detection is just as critical as defending against external threats, but it requires a different toolset. Unlike malware or network intrusions, insider threats often can't be blocked by antivirus or firewalls. They demand deeper visibility, behavioral context, and AI-powered insights.

Flexible Deployment Options for Comprehensive TDIR

Organizations have different operational needs. Exabeam meets them with two powerful platforms for insider threat detection, investigation, and response (TDIR): the cloud-native New-Scale Security Operations Platform and self-hosted LogRhythm SIEM Platform.

New-Scale Platform

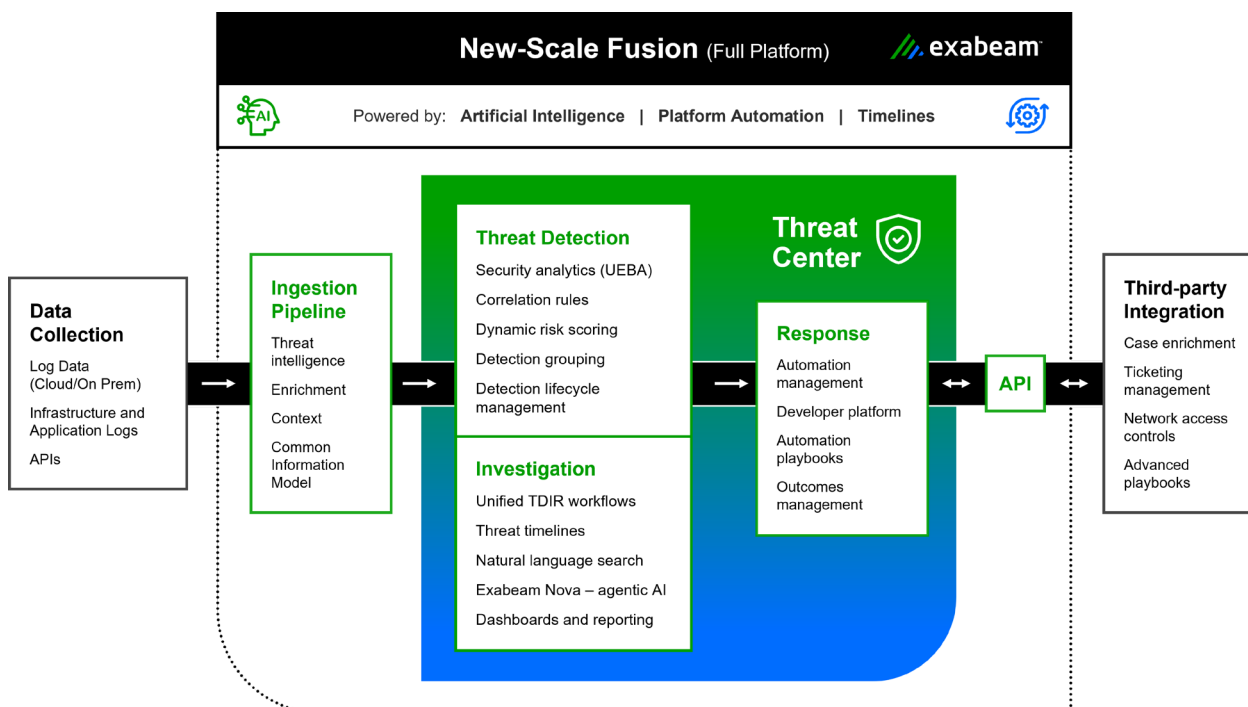
**Cloud native. AI powered.
Built for scale.**

The [New-Scale Platform](#) delivers unified TDIR workflows in a modern, cloud-native architecture. Built for automation and speed, it enables analysts to detect and respond to insider threats faster and more confidently.

Highlights:

- **AI-driven detection:** 500+ behavioral models baseline user and device activity to assign risk scores and generate timelines.
- **Scalable performance:** Processes 2M+ EPS and stores up to 100 PB per instance. Fast search and intuitive dashboards accelerate insights.
- **Automated response:** Automates alert triage, investigation, and response using ML-driven timelines and SOAR integrations.
- **Agentic AI support:** [Exabeam Nova](#) in [Threat Center](#) provides AI-generated summaries, checklists, and investigation support.
- **Outcomes Navigator:** Maps detection use cases to ATT&CK to help prioritize efforts and close gaps.

By learning what's normal and revealing what's not, the New-Scale Platform detects insider threats traditional tools miss, even when valid credentials are used.



LogRhythm SIEM Platform

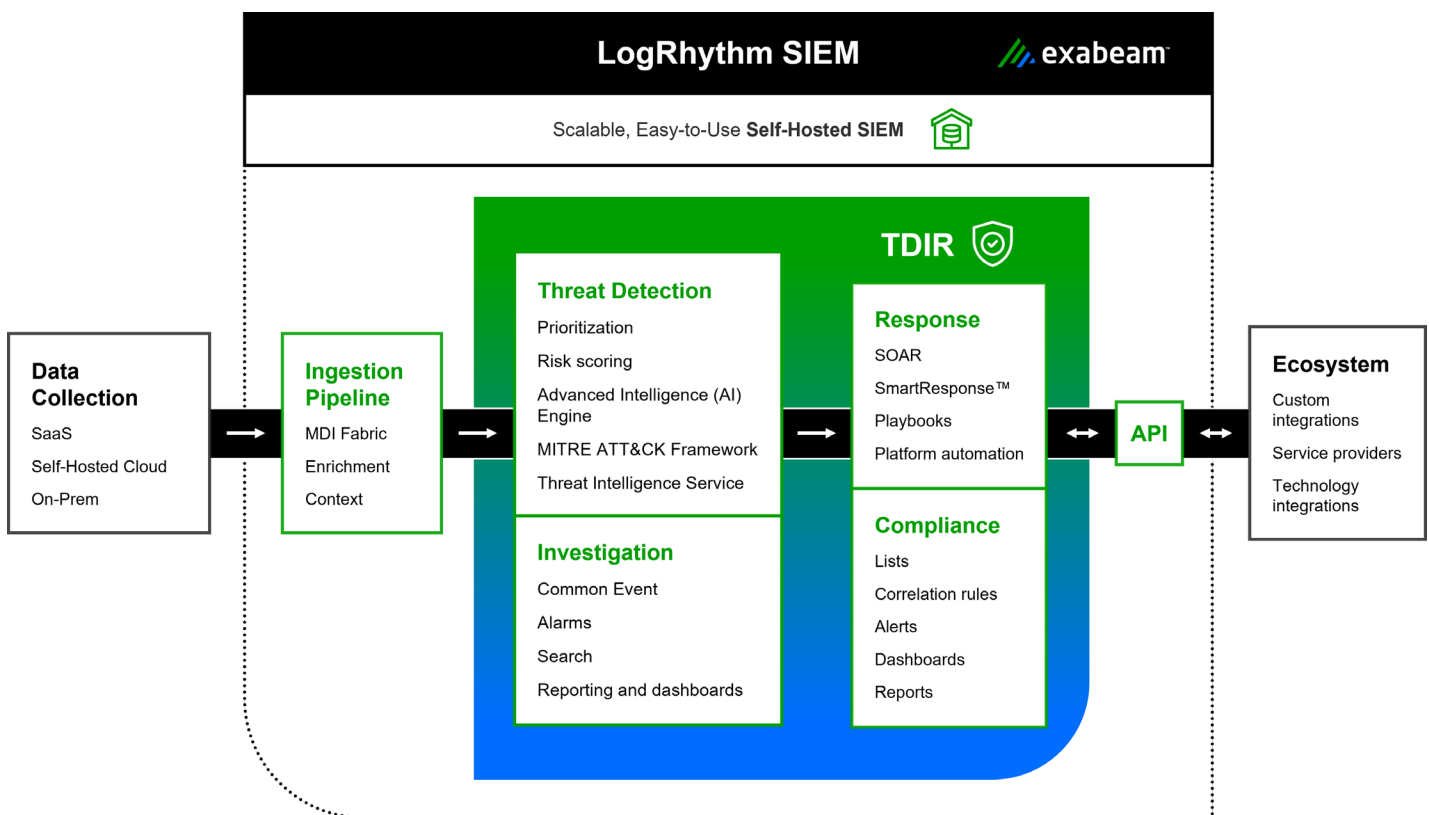
Self hosted. Integrated. Trusted by resource-conscious teams.

The [LogRhythm SIEM Platform](#) is designed for organizations that need full control of their security infrastructure on premises. It delivers robust threat visibility, flexible integrations, and deep analytics across hybrid environments.

Highlights:

- **Threat detection at speed:** More than 1,100 prebuilt correlation rules drive rapid alerting and detection across thousands of log sources.
- **Enriched analytics:** [Machine Data Intelligence \(MDI\) Fabric](#) normalizes and enriches logs for improved searchability and context.
- **Built-in SOAR:** Automates incident response, integrates with over 80 partners, and supports case management from investigation to resolution.
- **Compliance ready:** Comes with prebuilt content for 28 regulatory frameworks, helping teams meet requirements faster.
- **Scalable and customizable:** Adapts to growing data volumes and integrates seamlessly with existing infrastructure.

With biweekly knowledge base updates and broad vendor support, the platform delivers immediate operational value and long-term flexibility.



Choose What Works for You

Whether you need the elasticity and automation of a cloud-native platform or the control and customization of a self-hosted solution, Exabeam has you covered.

- **New-Scale Platform:** Ideal for organizations prioritizing cloud-first agility, automated workflows, and advanced AI-powered threat detection
- **LogRhythm SIEM Platform:** Ideal for environments requiring on-premises control, deep integrations, and proven TDIR workflows.

Both platforms help reduce risk, eliminate inefficiencies, and improve insider threat response, equipping your team to stay ahead of evolving threats with clarity and control.

About Exabeam

Exabeam is a leader in intelligence and automation that powers security operations for the world's smartest companies. As a global cybersecurity innovator, Exabeam provides industry-proven, security-focused, and flexible solutions for faster, more accurate threat detection, investigation, and response (TDIR).



Learn more at
www.exabeam.com →

Exabeam, the Exabeam logo, New-Scale SIEM, Detect. Defend. Defeat., Exabeam Fusion, Smart Timelines, Security Operations Platform, and XDR Alliance are service marks, trademarks, or registered marks of Exabeam, Inc. in the United States and/or other countries. All other brand names, product names, or trademarks belong to their respective owners.
© Exabeam, Inc. All rights reserved.